

Securing the AI Perimeter

Building Zero-Trust Integration Patterns for AI-Driven Pricing in SAP

SAP TECHED SESSION

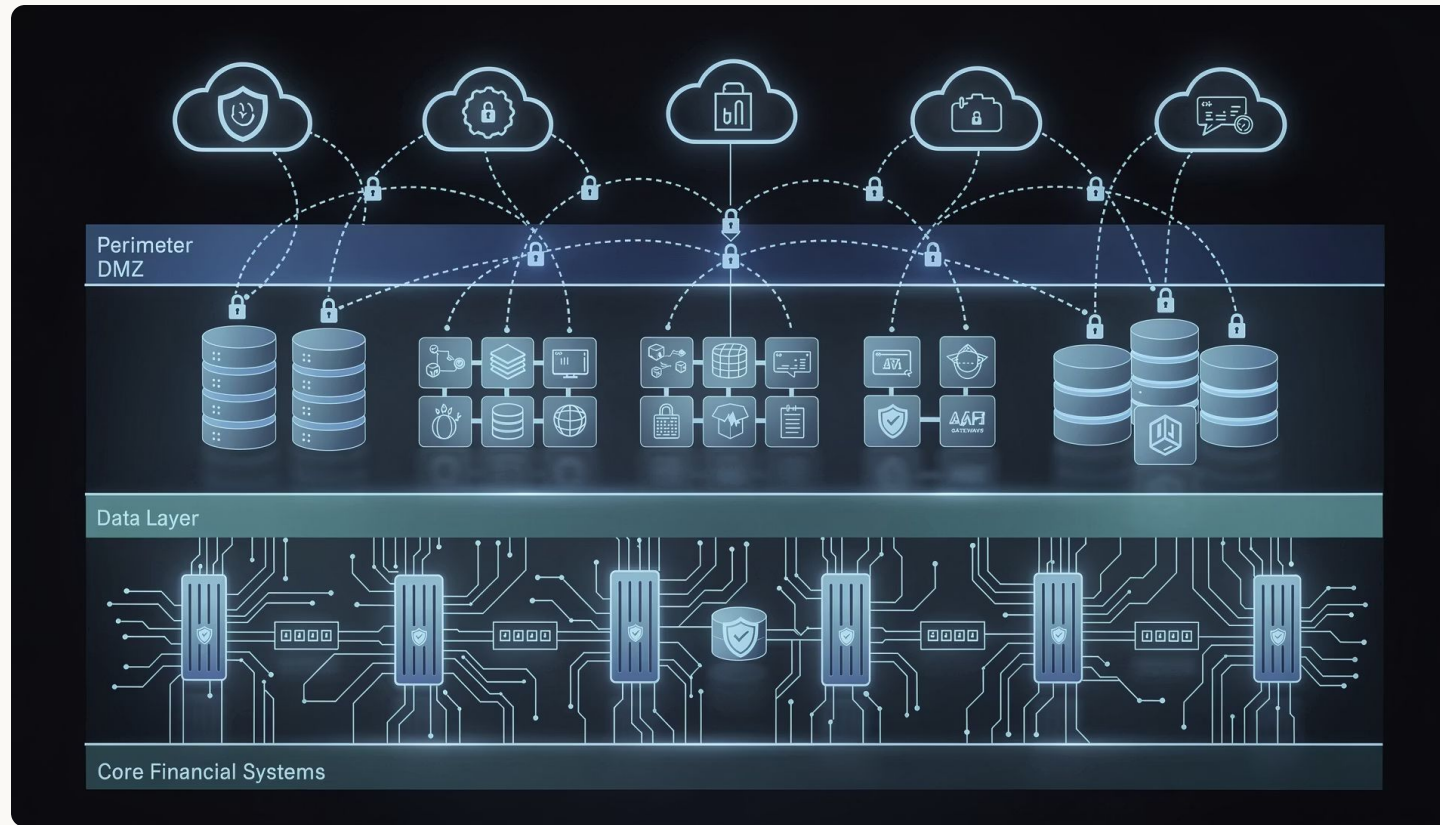
PRODUCTION-TESTED ARCHITECTURE

Presented by **Sirisha Ayyagari**



The Challenge

Innovation Cannot Come at the Cost of Control



Enterprises racing to embed AI into core financial systems face a hard constraint: **innovation cannot compromise system integrity, auditability, or financial control.**

Pricing engines sit inside the Order-to-Cash pipeline. Any external AI integration must be secured, governed, and clean-core compliant from day one - not retrofitted after a breach or audit failure.

Session Agenda

01

The Hard Security Boundary

Why SAP retains sole transactional authority

02

Integration Architecture

HTTP APIs, BAdI extension points, and clean-core compliance

03

DevSecOps Guardrails

Rate limiting, output validation, and circuit breakers

04

Governance & Auditability

Traceability for every AI-influenced pricing decision

05

Your Replicable Blueprint

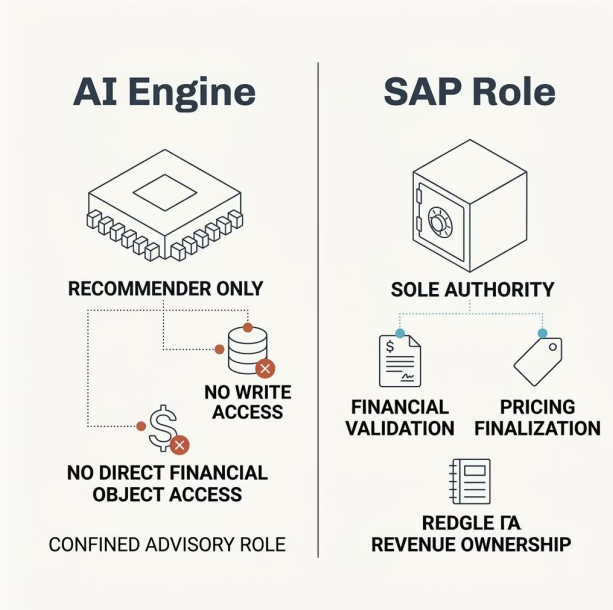
Threat modeling, ABAP patterns, and rollback paths

CHAPTER 1

The Hard Security Boundary

Defining what the AI engine can - and categorically cannot - do inside your ERP landscape.

The Fundamental Principle: Stateless AI, Stateful SAP



The architecture enforces a single, non-negotiable rule:

- **SAP retains sole authority** over transactional consistency and financial validation
- The AI engine is confined to a **stateless recommendation role** with zero write access to core financial objects
- Every pricing decision is ultimately owned, validated, and committed by SAP - never by the model

Threat Model: Where AI Integrations Go Wrong

Excessive Privilege

AI service accounts granted write access to financial objects - enabling direct manipulation of pricing, discounts, or revenue data without human validation.

Unsanitized Model Output

Raw model recommendations passed directly into pricing logic without boundary checks - a vector for injection attacks or wildly incorrect pricing.

Retrofit Security

Integration shipped fast and secured later - after a breach, an audit finding, or a compliance gap surfaces in production under load.

No Rollback Path

A misbehaving model with no circuit breaker can silently corrupt pricing decisions across thousands of orders before detection.

CHAPTER 2

Integration Architecture

HTTP-based APIs, SAP BAdI extension points, and a zero-modification approach to clean-core compliance.

The Production-Tested Architecture



Integration is implemented entirely through standard SAP extension points. Zero modification to standard SAP objects - preserving upgrade safety and minimizing attack surface by design.

Clean-Core Compliance by Design

Why BAdI?

Business Add-Ins (BAdIs) are SAP's sanctioned extensibility mechanism. Using them means:

- No modifications to standard SAP objects
- Full upgrade safety preserved across releases
- Auditable extension points with defined lifecycle
- Minimal attack surface - integration logic is isolated and replaceable

API Boundary Design

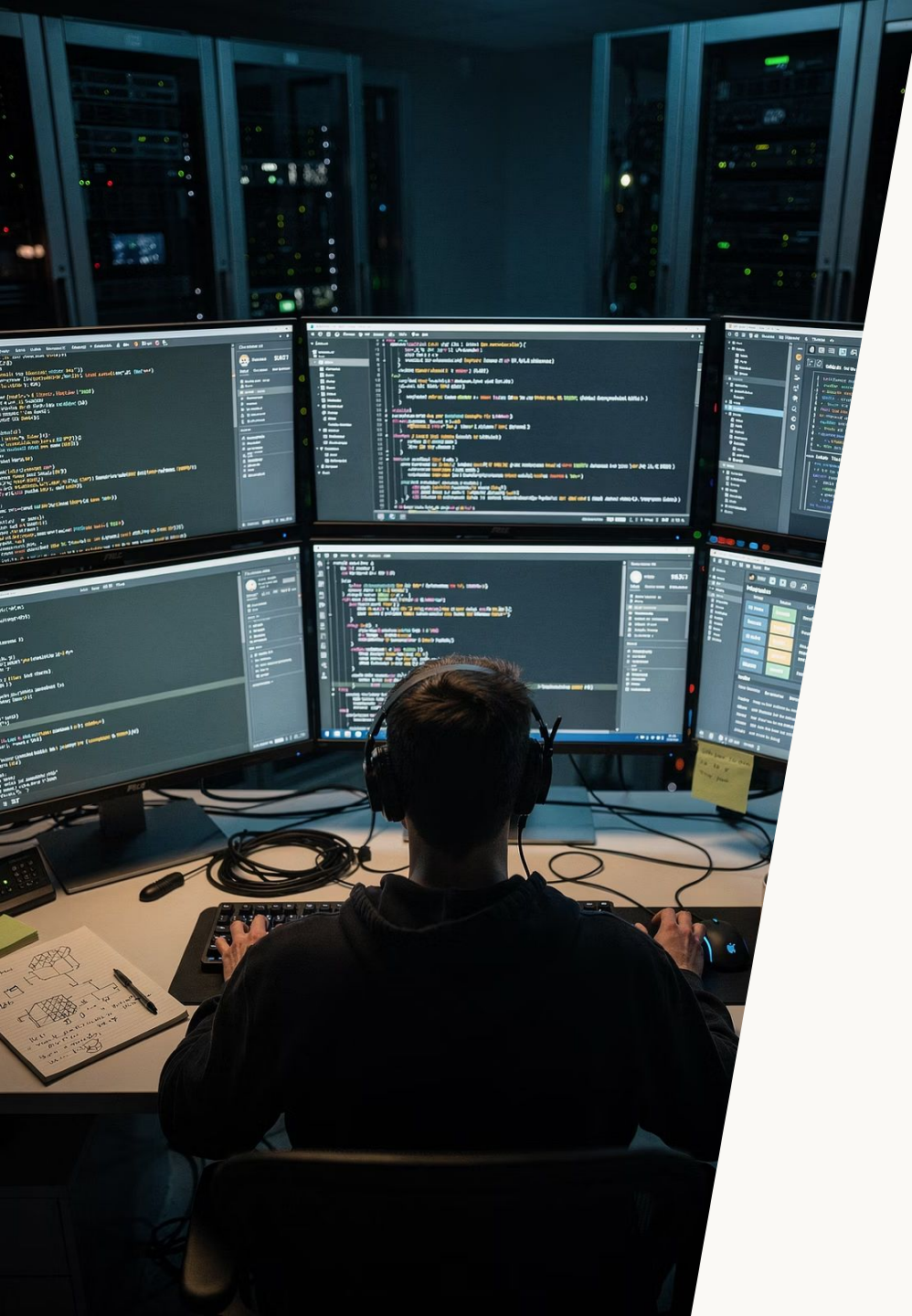
The HTTP API layer between SAP and the AI engine is hardened at the boundary:

- Secure authentication between SAP and the AI engine
- Least-privilege access controls between the AI layer and SAP
- Strict request/response schema contracts
- Rate limiting enforced at the gateway - not the model

CHAPTER 3

DevSecOps Guardrails

Securing the AI-to-SAP boundary with output validation, least-privilege access, and automated circuit breakers.



The Four Guardrail Layers

1



API Security & Rate Limiting

Every call to the AI engine is authenticated, rate-limited, and logged. Burst traffic cannot overwhelm the pricing boundary or bypass controls.

2



Output Validation & Sanitization

Every model recommendation is validated against pricing bounds, business rules, and schema contracts before it touches a financial transaction.

3



Least-Privilege Access

AI service accounts are scoped to read-only pricing context. No account used by the AI layer can write to SD, FI, or CO objects.

4



Circuit Breakers & Rollback

A misbehaving model triggers automatic fallback to rule-based pricing. No degraded model state can propagate into committed financial data.

ABAP-Side Guardrail Patterns

The BAdI implementation enforces guardrails in ABAP before any AI recommendation reaches pricing logic:

- **Range validation:** Price recommendations outside configured bounds are rejected outright - not flagged, rejected
- **Schema enforcement:** Malformed or unexpected response structures raise exceptions caught before order processing continues
- **Timeout handling:** Hard timeouts on HTTP calls prevent model latency from stalling order pipelines
- **Fallback activation:** On any exception, SAP falls back to approved pricing tables - the model is bypassed cleanly

1

Call AI API

Authenticated, rate-limited HTTP request

2

Validate Response

Schema + business rule checks in ABAP

3

Apply or Reject

Pass to pricing or trigger fallback

4

Log Decision

Full audit trail regardless of outcome

CHAPTER 4

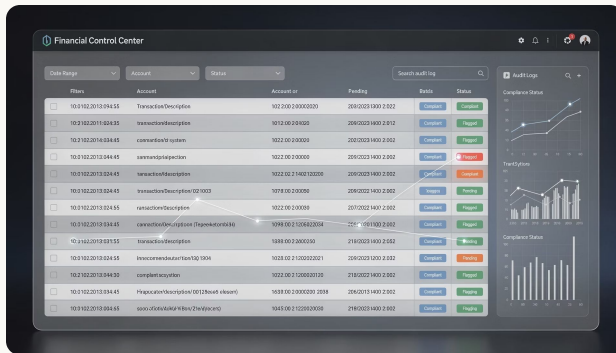
Governance & Auditability

Every AI-influenced pricing decision is logged, traceable, and defensible to internal audit and regulatory review.

Logging Every AI-Influenced Pricing Decision

Governance is not optional when AI touches Order-to-Cash. The logging layer captures:

- **Input context** sent to the model - customer, material, conditions
- **Raw recommendation** returned by the AI engine
- **Validation outcome** - accepted, rejected, or fell back
- **Final price applied** and the SAP document it was committed to
- **Timestamp and identity** of the service account that made the call



☐ This trace satisfies internal audit requirements and provides the evidentiary chain needed for regulatory review of AI-assisted financial decisions.



Your Replicable Blueprint



Threat-Model First

Map every trust boundary before writing a line of integration code. Identify what the AI can read, what it can never write, and what triggers a fallback.



BAdI + HTTP = Clean Core

Implement integration exclusively through SAP extension points and secured APIs. Zero standard object modification is non-negotiable.



Build Failure Into the Design

Circuit breakers and rollback paths are first-class architectural requirements - not operational afterthoughts added post-launch.



Log Everything, Justify Every Decision

Full audit traceability for AI-influenced pricing is not a compliance checkbox - it is the foundation of enterprise trust in AI-driven financial systems.

Thank You